

Audit de Conformité et Référentiels (ANSSI, CIS, RGPD)

Objectifs :

- Comprendre l'importance des référentiels de sécurité (ANSSI, CIS Benchmarks).
- Savoir réaliser un audit de conformité automatisé sous Linux.
- Savoir vérifier et durcir les politiques de mots de passe locales sous Windows.

1. Introduction

Historiquement, la sécurisation des systèmes dépendait de l'expérience personnelle de l'administrateur. Chaque entreprise avait sa propre définition d'un "système sécurisé". Avec l'explosion des cyberattaques et l'instauration de réglementations strictes (RGPD, HDS, directive NIS 2), il est devenu impératif de s'appuyer sur des standards universels.

Des organismes gouvernementaux (comme l'**ANSSI** en France) et des consortiums internationaux (comme le **CIS - Center for Internet Security**) publient aujourd'hui des guides de configuration de référence appelés *Benchmarks*.

1.1 Le problème résolu par les référentiels

L'application de ces guides résout le problème de l'hétérogénéité. Au lieu de se demander quels ports fermer ou quelle longueur de mot de passe imposer, l'administrateur dispose d'une matrice validée par des experts. Cela permet de :

- **Prouver la conformité** du système d'information lors d'audits techniques (ex: CNIL / RGPD).
- **Garantir un standard** sur tout le parc informatique (*Baseline*).

1.2 Avantages et Inconvénients

- **Avantages** : Fournit un cadre légal défendable post-incident, et offre une couverture exhaustive (réseau, droits fichiers, logs).
- **Inconvénients** : L'application aveugle et stricte (ex: "Level 2" du CIS ou profil "Durci" de l'ANSSI) casse presque systématiquement les applications métiers anciennes (*Legacy*).

2. Stratégie de Déploiement en Entreprise

- **Déploiement par étapes** : On n'applique jamais un *Benchmark* complet d'un seul coup. On commence par le profil de base (ex: CIS Level 1), on valide le fonctionnement métier, puis on itère.
- **Gestion des exceptions** : Une non-conformité est acceptable si elle est justifiée, documentée et compensée par une autre mesure de sécurité (ex: on tolère un mot de passe plus faible si l'authentification multifacteur - MFA - est obligatoire).

- **Automatisation** : La configuration dérive toujours avec le temps (*Configuration Drift*). L'audit doit être exécuté régulièrement via des outils spécialisés.

3. Outils et Commandes d'Audit

Pour valider la conformité d'un système, nous utilisons des outils et commandes permettant d'extraire rapidement l'état de la configuration.

3.1 Cible Linux : Audit automatisé avec Lynis

Lynis est l'outil open-source de référence pour l'audit de conformité sous Linux. Il vérifie des centaines de points de configuration et attribue un score de durcissement (*Hardening Index*).

- **Installer Lynis sur une base Debian/Ubuntu :**
`sudo apt-get update && sudo apt-get install lynis -y`

- **Lancer un audit complet du système :**
`sudo lynis audit system`

(Note : le scan prend quelques minutes. À la fin, l'outil affiche un récapitulatif coloré et un "Hardening index" sur 100).

- **Extraire uniquement les alertes (warnings) depuis le journal de l'outil :**
`grep -i warning /var/log/lynis.log`

3.2 Cible Windows : Audit des politiques locales (Secedit / Net Accounts)

Sur un serveur hors domaine Active Directory, les règles de sécurité (comme la complexité des mots de passe) sont gérées par la politique locale. Le guide d'hygiène de l'ANSSI impose des règles strictes sur ces mots de passe.

- **Vérifier la politique de mots de passe actuellement appliquée :**
`net accounts`
- **Modifier la stratégie d'historique (ex: mémoriser et interdire la réutilisation des 5 derniers mots de passe) :**
`net accounts /uniquepw:5`
- **Modifier l'âge maximal (expiration) du mot de passe (ex: 90 jours) :**
`net accounts /maxpwage:90`
- **Modifier la longueur minimale exigée (ex: 14 caractères) :**
`net accounts /minpwlen:14`
- **Exporter la configuration de sécurité locale pour l'analyser dans un fichier :**

```
secedit /export /cfg C:\secpol.inf
```

4. Commandes Complémentaires

Ces commandes vous seront utiles pour des vérifications plus poussées lors de vos audits.

- **Linux : Vérifier la conformité de l'algorithme de hachage des mots de passe.**
L'ANSSI recommande au minimum SHA-512 ou YESCRYPT. On vérifie cette configuration dans le fichier login.defs :

```
grep ENCRYPT_METHOD /etc/login.defs
```
- **Linux : Vérifier la date d'expiration des mots de passe d'un utilisateur spécifique (ex: root).**

```
sudo chage -l root
```
- **Windows : Analyser finement le fichier d'export de la politique locale avec PowerShell.**
Au lieu d'ouvrir le fichier .inf dans le bloc-notes, on peut utiliser PowerShell pour isoler la ligne qui nous intéresse (ex: la variable de l'historique des mots de passe) :

```
Get-Content C:\secpol.inf | Select-String "PasswordHistorySize"
```